b. **Identifier les sources de risques** (qui ou qu'est-ce qui pourrait être à l'origine de chaque évènement redouté ?), en prenant en compte des sources humaines internes et externes (ex. : administrateur informatique, utilisateur, attaquant externe, concurrent) ainsi que des sources non humaines internes et externes (ex. : eau, épidémie, matériaux dangereux, virus informatique non ciblé).

c. **Identifier les menaces** (qu'est-ce qui pourrait permettre que chaque évènement redouté survienne ?). Ces menaces surviennent sur les supports identifiés précédemment (matériels, logiciels, canaux de communication, supports papier, etc.), qui peuvent être :
   - utilisés de manière inadaptée (ex. : abus de droits, erreur de manipulation) ;
   - modifiés (ex. : piégeage logiciel ou matériel ou « *keylogger* », installation d'un logiciel malveillant) ;
   - perdus (ex. : vol d'un ordinateur portable, perte d'une clé USB) ;
   - observés (ex. : observation d'un écran dans un train, géolocalisation d'un matériel) ;
   - détériorés (ex. : vandalisme, dégradation du fait de l'usure naturelle) ;
   - surchargés (ex. : unité de stockage pleine, attaque par déni de service).

d. **Déterminer les mesures existantes ou prévues** qui permettent de réduire chaque risque (ex. : contrôle d'accès, sauvegardes, traçabilité, sécurité des locaux, chiffrement, anonymisation).

e. **Estimer la gravité** (impact ou préjudice potentiel pour les personnes concernées) **et la vraisemblance** (probabilité qu'ils se réalisent) des risques, au regard des éléments précédents (exemple d'échelle utilisable pour l'estimation : négligeable, modérée, importante, maximale).

Le tableau suivant peut être utilisé pour formaliser cette réflexion :

Évènement redouté	Impacts sur les personnes	Principales sources de risques	Principales menaces	Mesures existantes ou prévues	Gravité pour les personnes	Vraisem-blance
Accès illégitime à des données						
Modification non désirée de données						
Disparition de données						

3. **Mettre en œuvre et vérifier les mesures prévues.** Si les mesures existantes et prévues sont jugées appropriées, il convient de s'assurer qu'elles soient appliquées et contrôlées (voir la fiche n°1 - Piloter la sécurité des données). Sinon, des mesures supplémentaires doivent être identifiées et mises en œuvre pour réduire la gravité et/ou la vraisemblance des risques associés.

- **Revoir régulièrement l'analyse de risques** et, en particulier, en cas de modification du système ou du contexte du traitement.